



ISC 互联网安全大会



360 互联网安全中心



工业互联网安全战略落地与推进建议

陶耀东 360企业安全集团 副总工程师

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



ISC 互联网安全大会



360 互联网安全中心

目录

工业互联网 IT/OT 融合的安全挑战？

工业互联网的安全应如何应对？

在工业互联网IT/OT协同防护的安全实践

工业互联网安全战略推进建议

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

工业互联网 IT/OT 融合的安全挑战？

SECURITY CHALLENGES FOR IT/OT INTEGRATION

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

工业互联网IT/OT融合的驱动力



有效的管理和保护工作的“物”，当应用他们产生的传感器数据进行分析 and 盈利时，

需要前所未有的**IT和OT组织合作获得竞争优势**

- 简化操作获得更大的**生产率**

Greater productivity with streamlined operations

- 提高**安全性与预测性**维护以避免危险的环境中

Improved safety with predictive maintenance to avoid dangerous environments

- 提高经营决策**精度和速度**

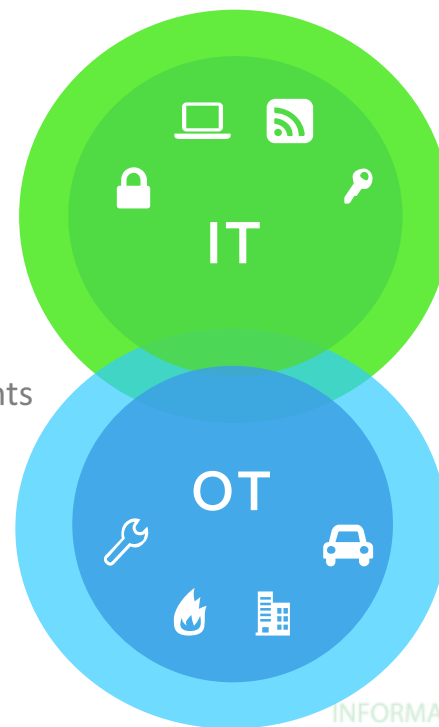
Increased accuracy and speed in operational decisions

- 减少所需**人力成本**

Cost savings with lesser manpower required

- 提高客户需求的**响应速度和服务能力**

Increasing responsiveness and service capabilities of customer requirements



企业在管理方面采用的手段、技术、制度、流程、文档等对信息流管理的统称

监视、控制和保护改变物理环境的系统

Gartner

ZERO TRUST SECURITY

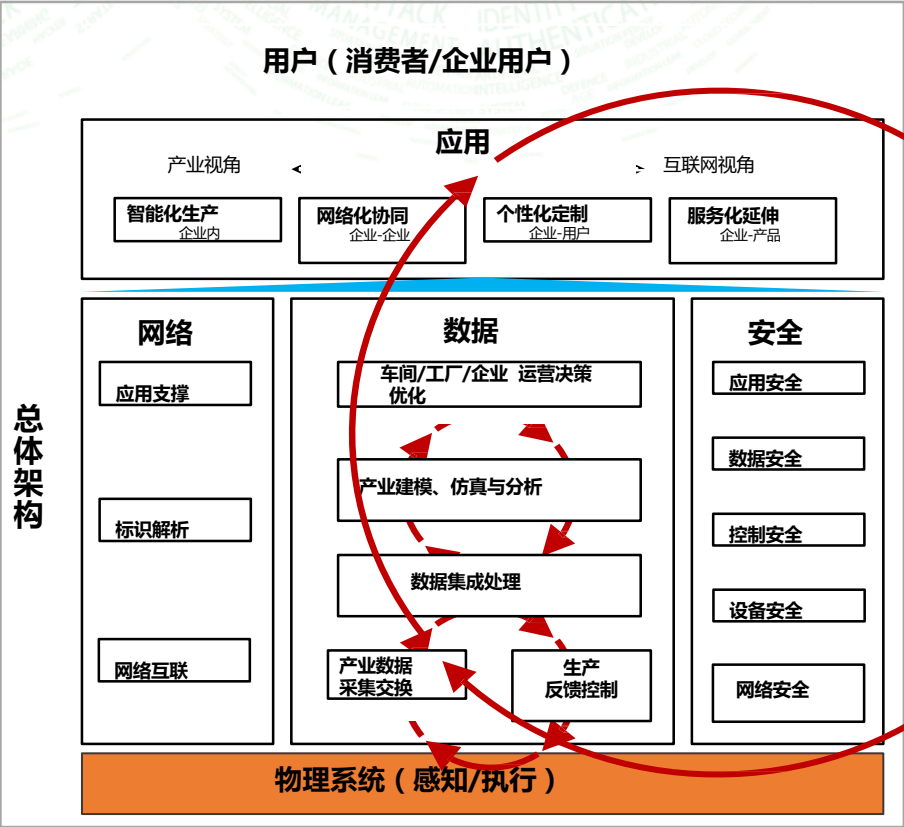
工业互联网 = 工业物联网 (OT) + 工业关联的消费性互联网 (IT)

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China

我国工业互联网总体架构



三大智能化闭环：智能生产控制、智能运营决策优化、消费需求与生产制造精确对接



表现：攻击入口多、防御剖面大！ 后果：带来物理伤害、威胁生命！ 原因：缺乏现代威胁理解和安全架构

IT环境与OT环境 安全功能差异



安全功能	IT	OT
防病毒和移动代码	很常见，轻松部署和更新。用户可以控制定制可以是基于资产或基于企业的	内存的限制 要求可能会影响ICS；只能通过售后解决方案保护传统系统；通常需要“排除”文件夹 以避免程序隔离关键文件
补丁管理	容易定义；企业范围内实施；可以远程和自动化	成功的安装补丁程序 需要长时间验证 ；定制性OEM产品难打补丁；可能影响ICS功能；资产所有者需要明确定义可接受的风险
技术生命周期	2~3年 ；大量供应商；无处不在的升级	10~20年 ；通常是单个供应商；
资产分类	常用，每年执行一次 ；结果驱动支出	必需时执行； 资产可见性低 ；资产价值与适当对策没有联系
事件响应和取证	易于开发和部署；有明确监管规定；采用嵌入技术	侧重于 系统恢复活动 ；取证程序不成熟；需要良好的IT/ICS关系
物理和环境安全	范围可以从差（系统）到优秀（关键的IT系统）	通常对关键区域非常有用；现场设施的成熟度各不相同
安全系统开发	整个开发过程的一部分	长久以来，不是整个开发过程的一部分；供应商走向成熟，但比IT慢；核心 ICS解决方案在安全性方面困难重重
安全合规	取决于部门的监管监督	根据部门（而不是所有部门）的具体监管指导

IT/OT融合后带来的进一步挑战

- OT大量采用IT设备和技术，**IT安全风险**随之而来，并将成为**主要威胁**
- IT和OT安全常常由两个**不同团队管理**，带来管理效率和有效性的挑战

ZERO TRUST SECURITY

IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

案例1：8.3 台积电勒索停产事件

(网络安全+控制安全)

IT/OT状态

- 台湾三工厂直接IT、Ot融合互联，全球多工厂
- IT和OT网络融合
- 严格网络安全管控和U盘管控
- 大量机台接入网络，标准SOP
- 与台湾以外工厂防火墙连接

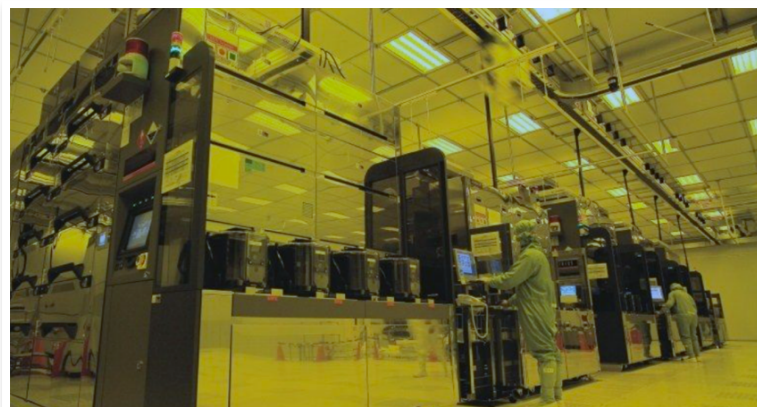
攻击过程

- 8月3日周五，新机台安装引入病毒
- 数分钟内wannacry大规模攻击3个工厂停产，机器蓝屏重启损失严重，受影响机器超万台
- 8月6日下午召开记者会：应对完毕，损失：近2亿美元、毛利降1%

解决

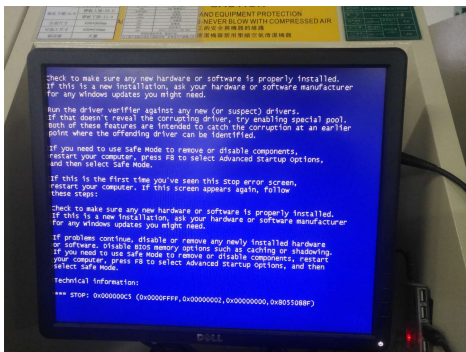
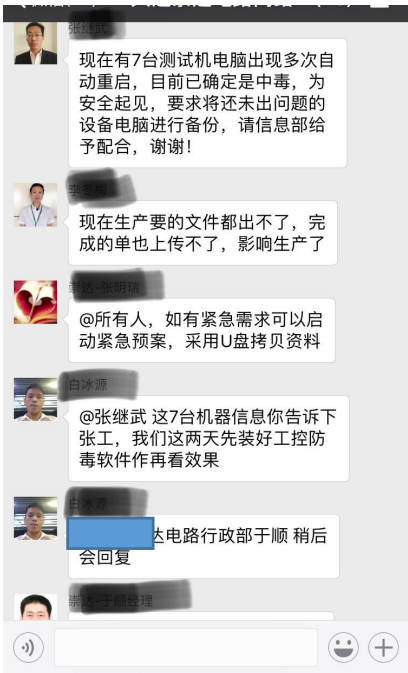
- 建立防呆机制（人和技术协同）
- 推动网络安全保险

近一年：航空界的波音公司、汽车界的雷诺、日产与本田、货运界的 **Maersk**、物流业的 **FedEx**，均遭受到了勒索病毒的攻击损失巨大？



案例2：某电路板企业（控制安全）

2018年4月3日接到客户的应急需求：东北某电路板企业有200台左右工控机，50台已被Wannacry感染出现反复蓝屏或重启现象，严重影响正常生产，大量订单积压



进行安全服务应急响应后，部署工业安全产品，进行安全防护

案例3：某装备企业上千台工程机械“失联” (设备安全)

事件背景

2016年6月底，某装备巨头向长沙县公安局报案。山东、江苏、山东、福建、内蒙、辽宁、新疆、广州、杭州等地陆续有数十台机械失联，导致技术研发和售后服务大受影响，更有大量客户恶意拖欠该公司货款，失联泵车价值高达数千万元

攻击过程

内鬼张某把ECC系统中的锁机模块删除后，重新制作成刷机镜像。就像破解后的windows系统一样，只要把这个镜像刷入泵机，就能实现解锁，使其“失踪”，每台收取1-2万；

启示：

1. 工业互联网带来商业模式创新
2. 安全问题也随之而来
3. 工业互联网平台也为安全带来了解决方案





ISC 互联网安全大会



360 互联网安全中心

未来将采用工业互联网、数字双胞胎，云制造，数字供应链等的超数字化工厂，安全问题可能产生可怕的后果！

In the future, Ultra-digital factories such as the Industrial Internet, Digital Twins, Cloud Manufacturing, Digital Supply Chains, etc. will be adopted. Security problems may have disastrous consequences.

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

AII联盟Q3全会工业企业调研（100+）

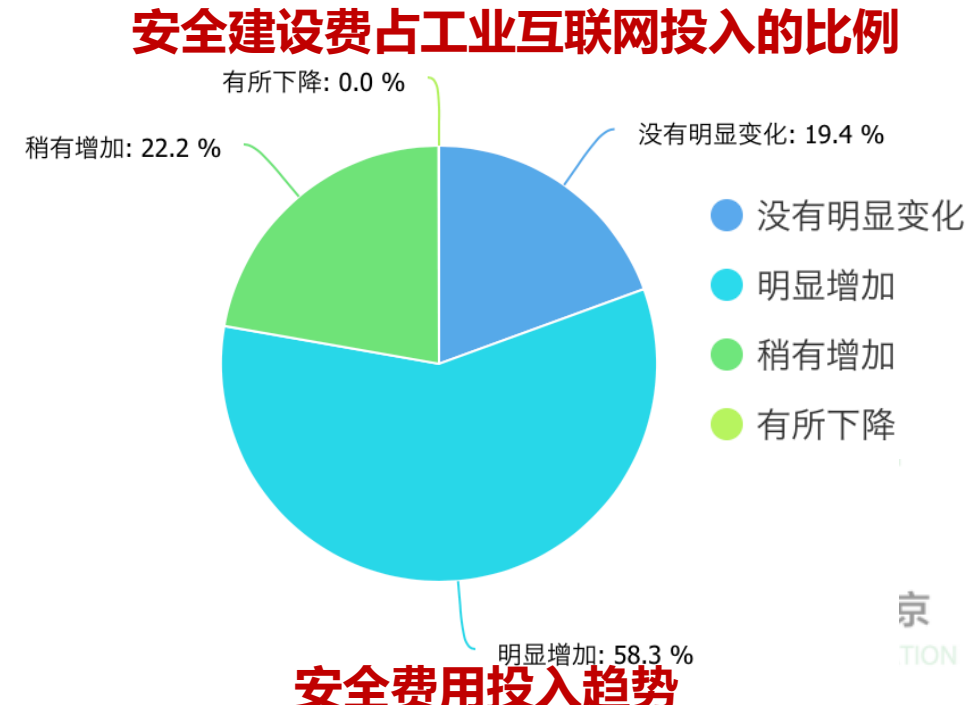
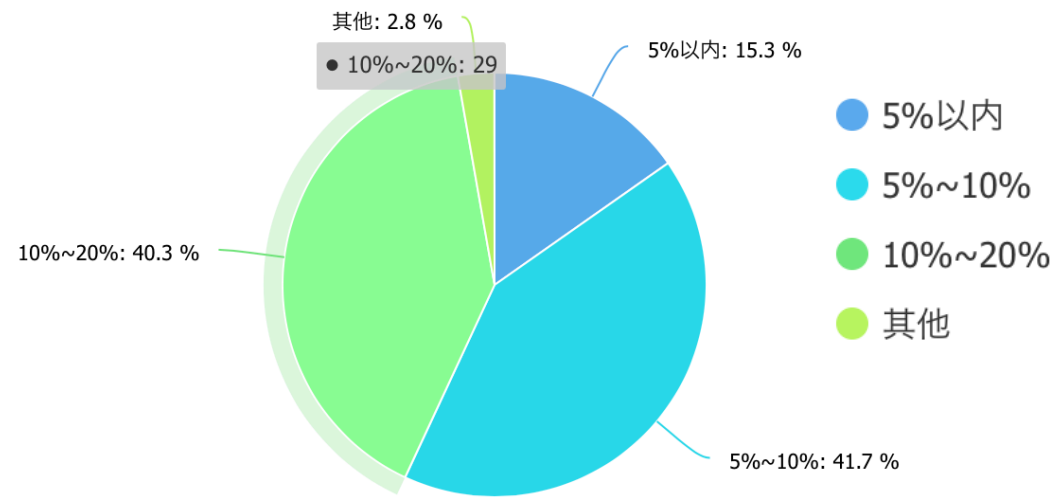


自我判断（乐观了？）：

- 1、行业内对自己单位的网络安全水平都有较高的认可
- 2、超过一半的企业认为自己公司不会遭受攻击

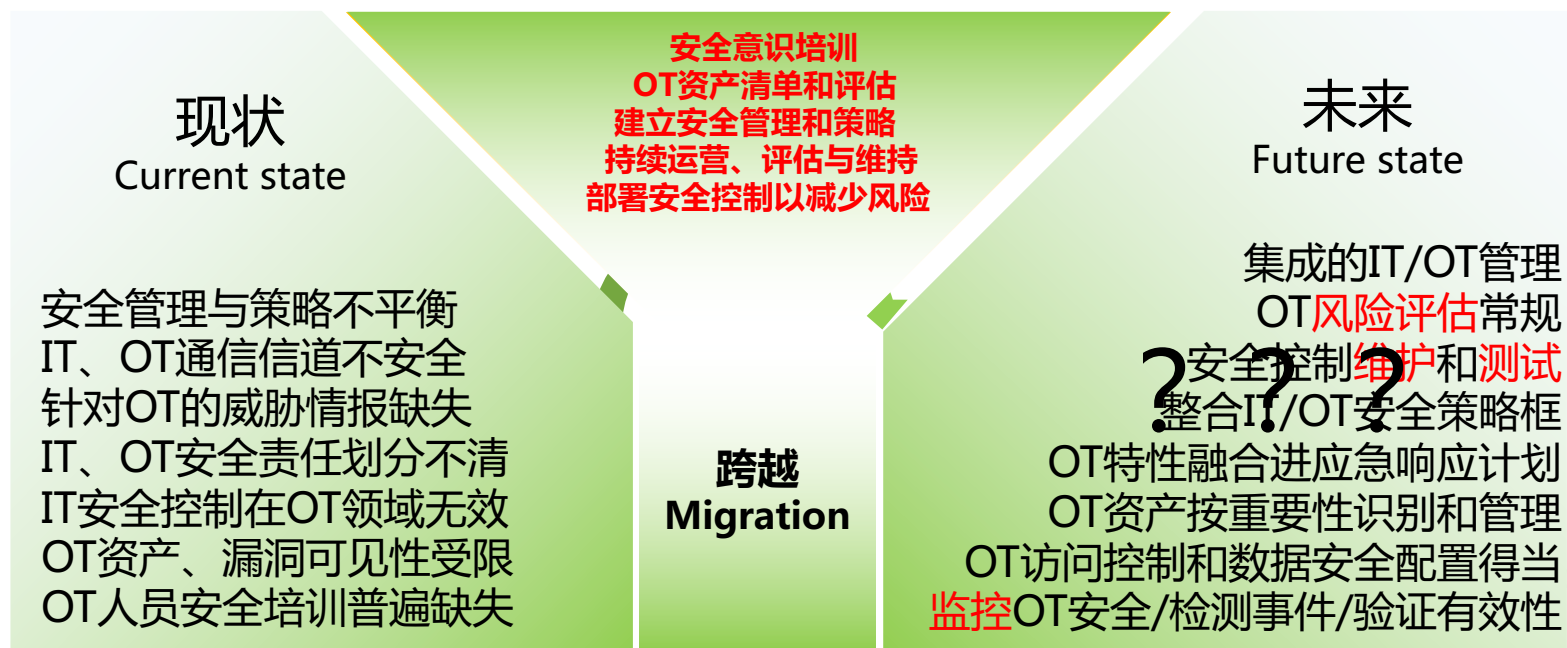
趋势：

- 1、国家政策的推动有利于工业互联网网络安全的实施
- 2、80%企业认为安全投入应占工业互联网投入的5%-20%
- 3、超76.4%认为高层领导决策决定公司的网络安全重视程度
- 4、工业网络安全最大挑战是安全人才匮乏



IT/OT一体化安全现状-GAP（鸿沟）

安全和风险管理者应该在充分了解**安全现状**的基础上，规划与设想企业安全生产的**未来安全图景**，并在两者之间寻找企业目前**缺失**的安全管理和控制手段，然后对症下药，找到**过度**至未来安全图景的方法。



安全战略路线图



ISC 互联网安全大会



360 互联网安全中心

工业互联网的安全如何应对？

HOW TO PROTECT INDUSTRIAL INTERNET SECURITY

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

IT/OT一体化安全发展路线

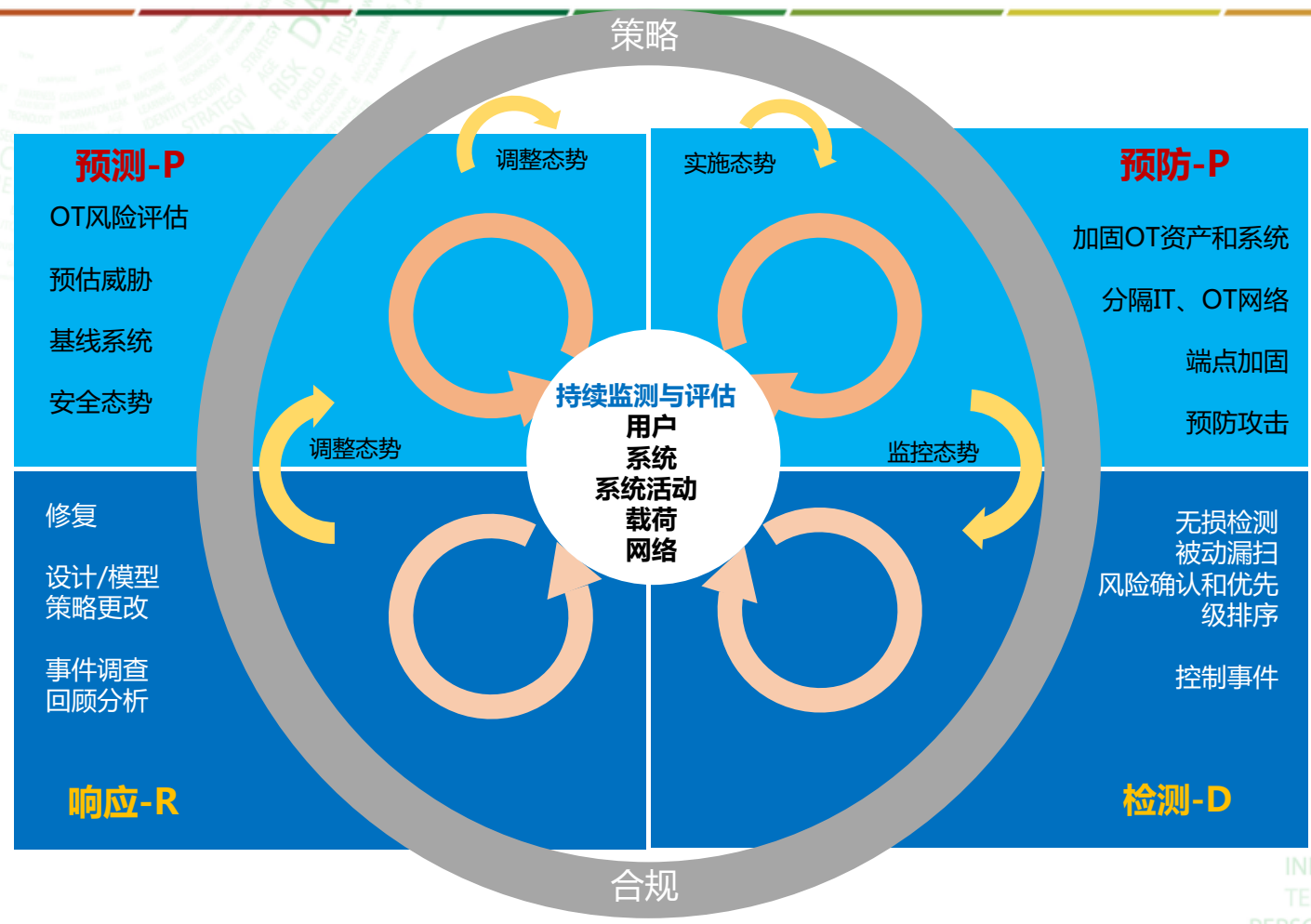


ZERO TRUST SECURITY

IT/OT一体化安全策略框架 (Gartner)
集成的IT和OT安全性是一个业务问题

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

IT/OT一体化的自适应防护架构

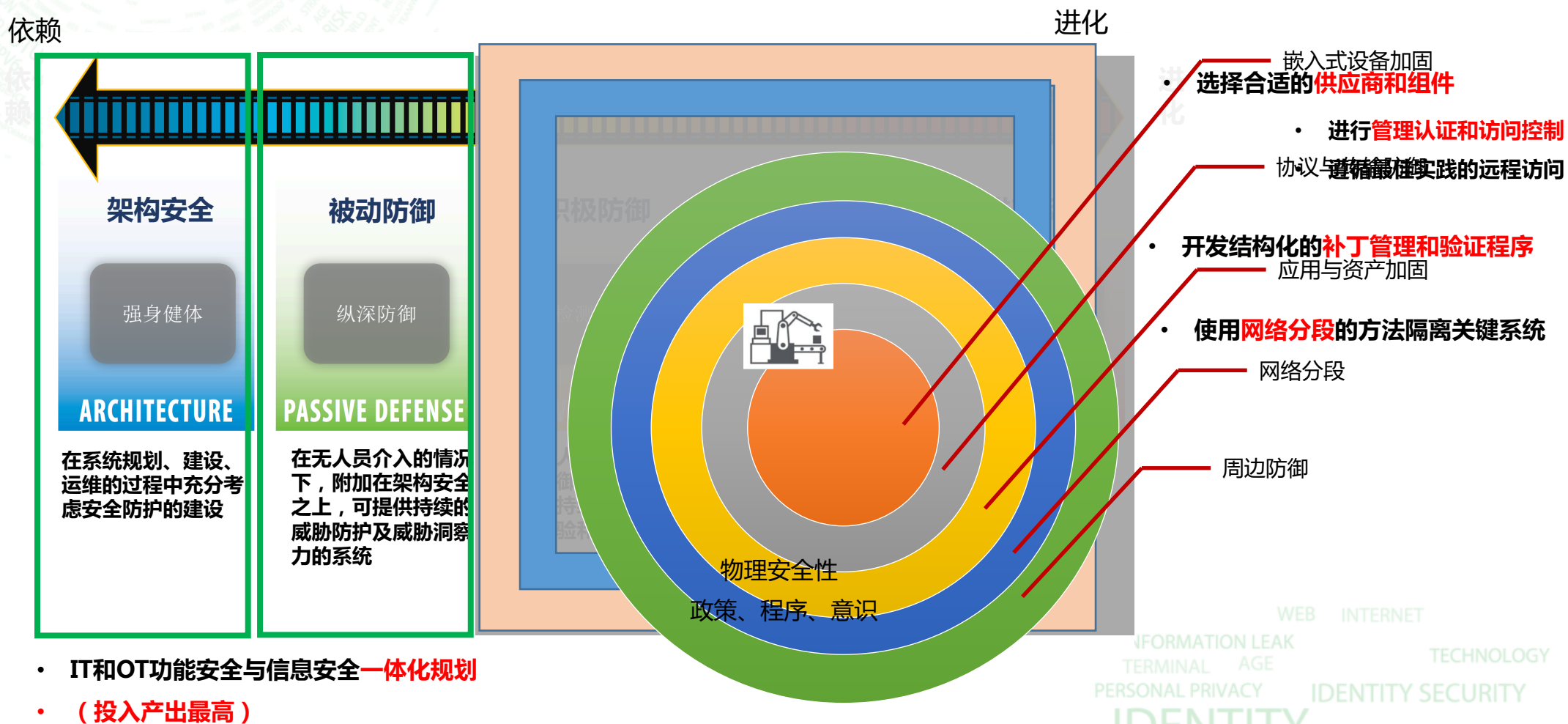


Gartner IT-OT自适应安全架构

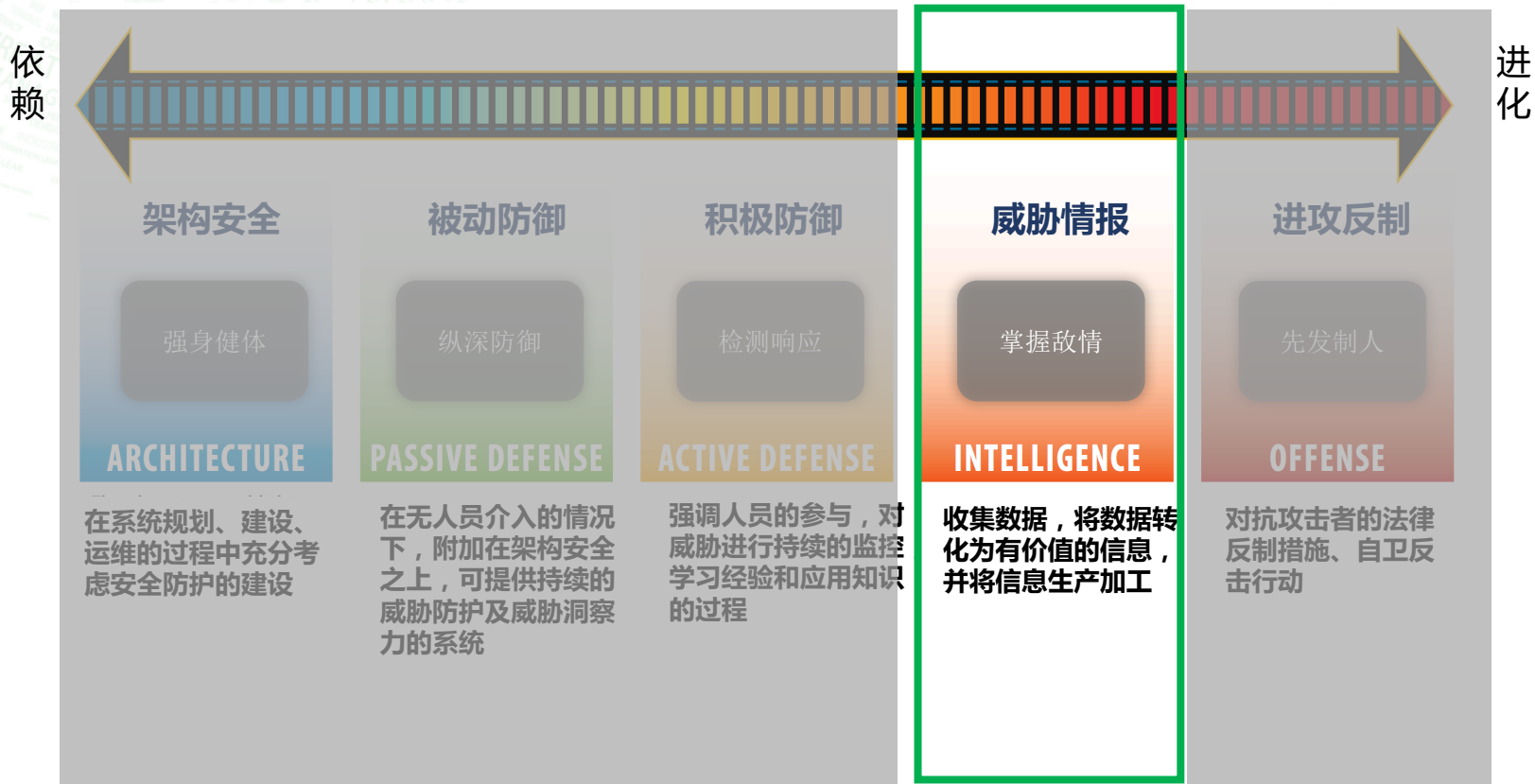
ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

安全的滑动演进 (Sliding Scale)



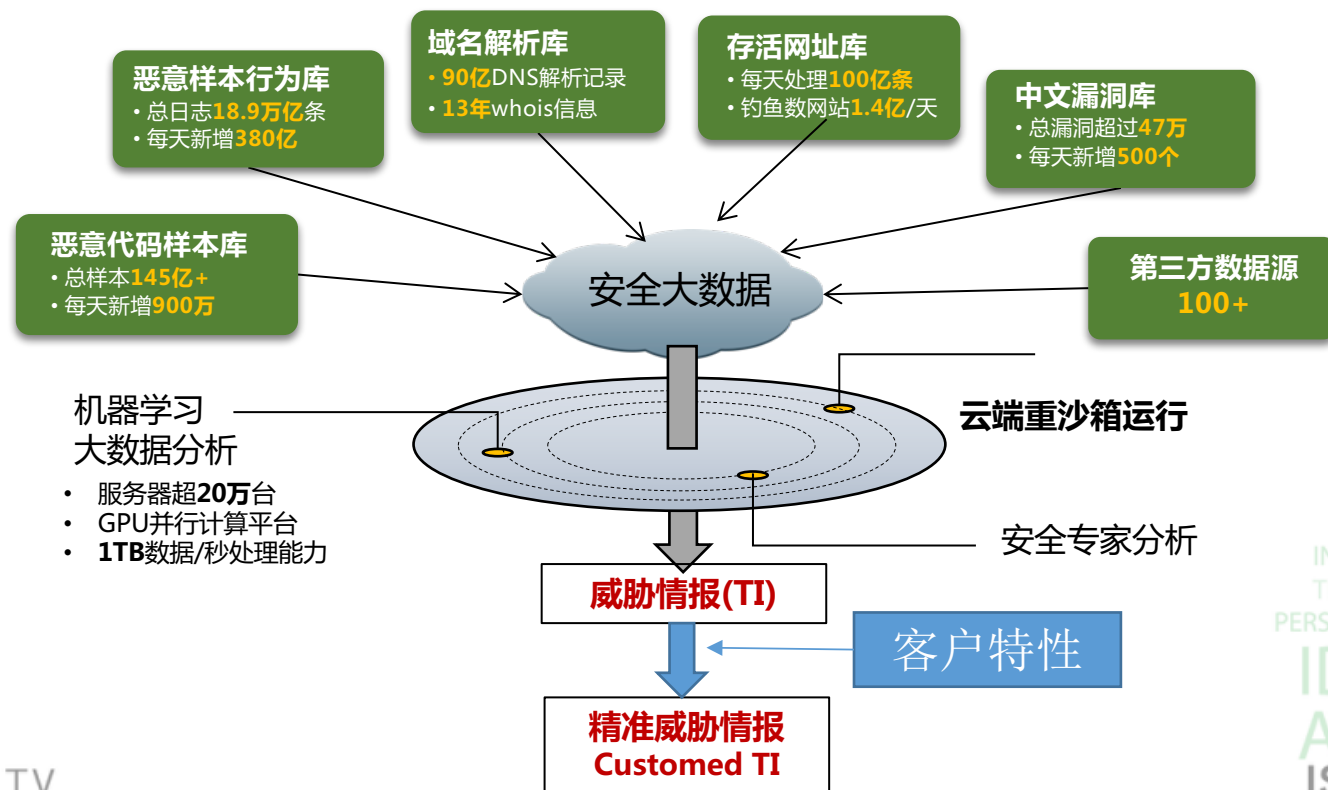
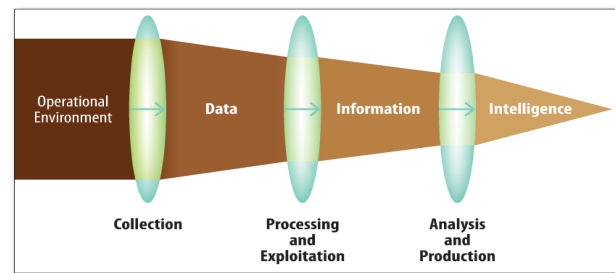
安全的滑动演进 (Sliding Scale)



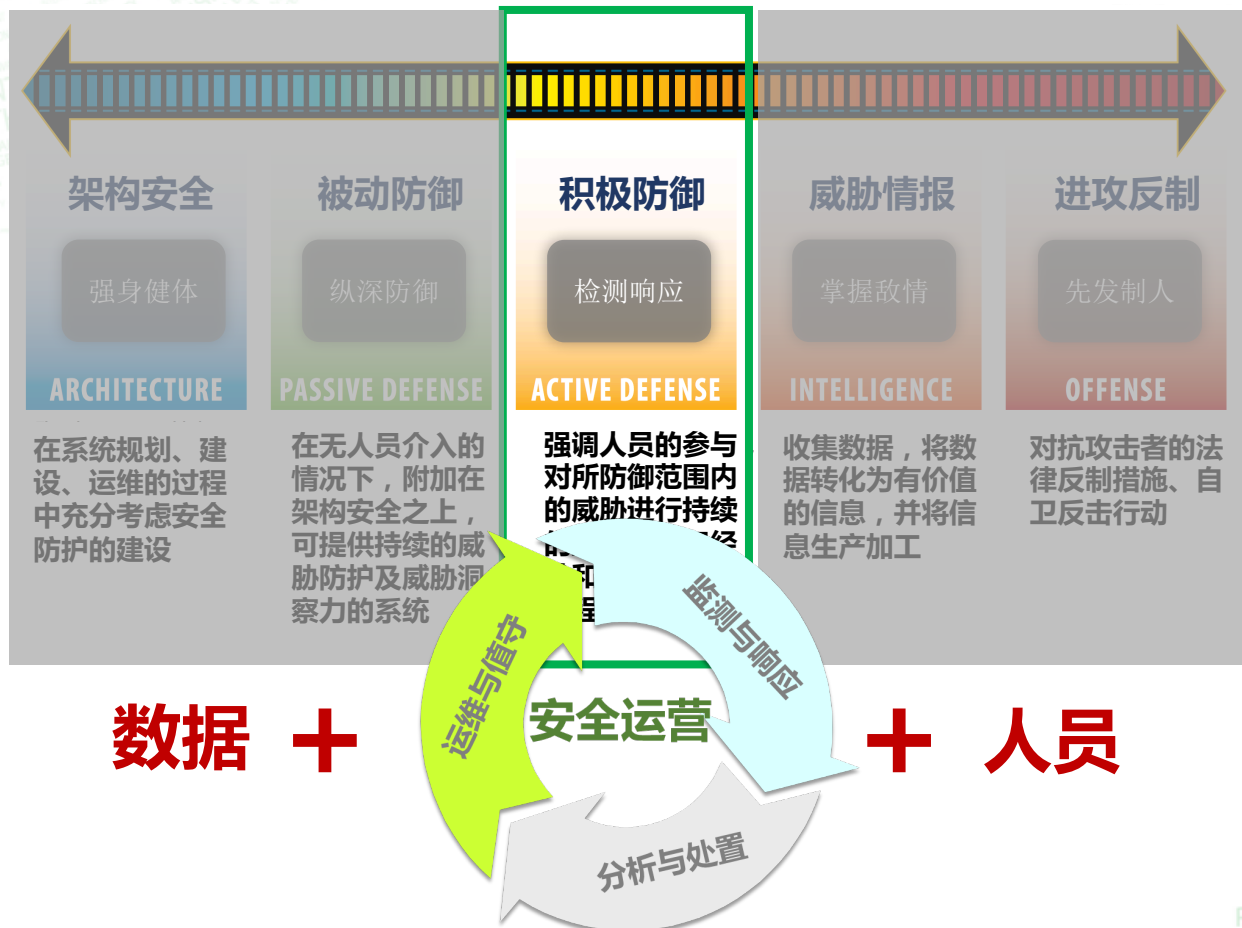
ZERO TRUST SECURITY

威胁情报的生产

- 程度如何？（指标）
- 现象如何？（表象）
- 后果怎样？（影响）
- 如何补救？（方案）
- 谁攻击的？（源头）
- 目标是谁？（目标）
- 为啥攻击？（动机）
- 手段如何？（工具）



安全的滑动演进 (Sliding Scale)



ZERO TRUST SECURITY



ISC 互联网安全大会



360 互联网安全中心

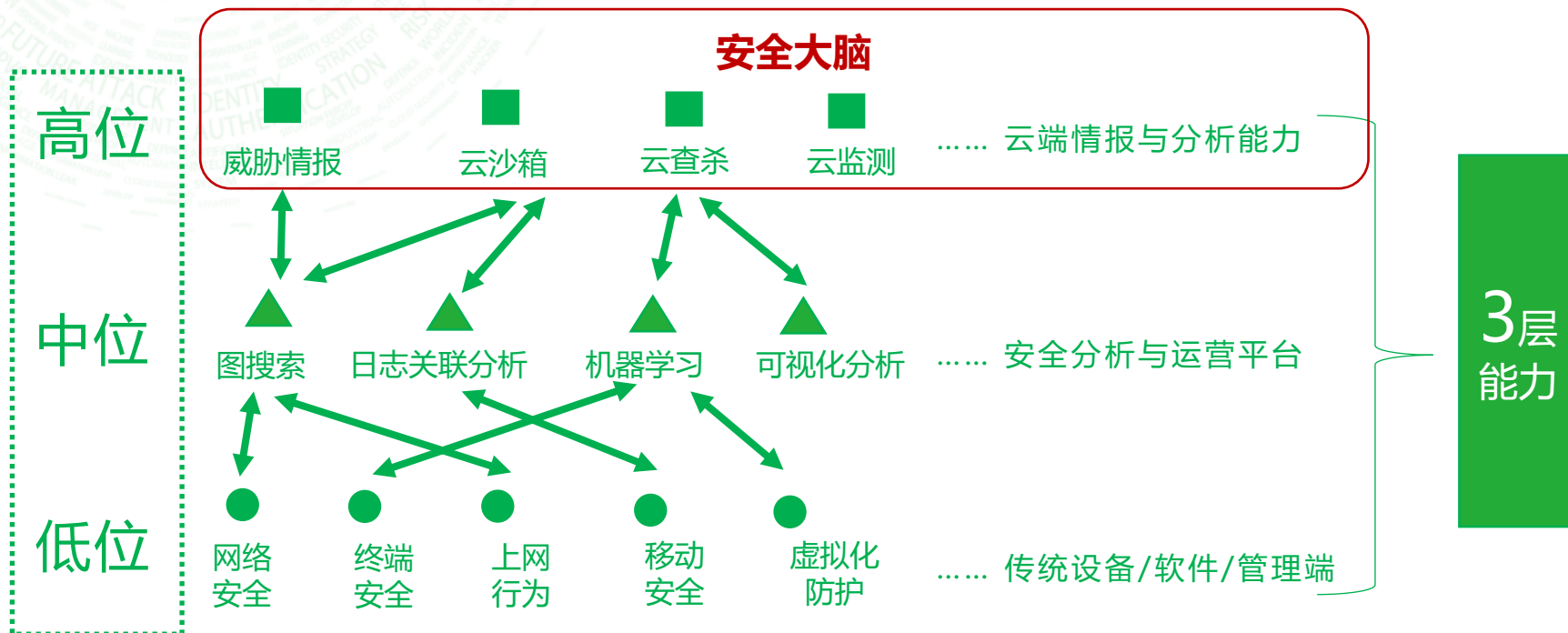
360在IT/OT协同防护的安全实践

SECURITY PRACTICE

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL AUTOMATION

数据驱动的安全能力构建



低位能力(Field)

- 数据的生产和采集
- 数据的广度和深度

中位能力(Middle)

- 数据的建模与分析
- 数据的治理与质量

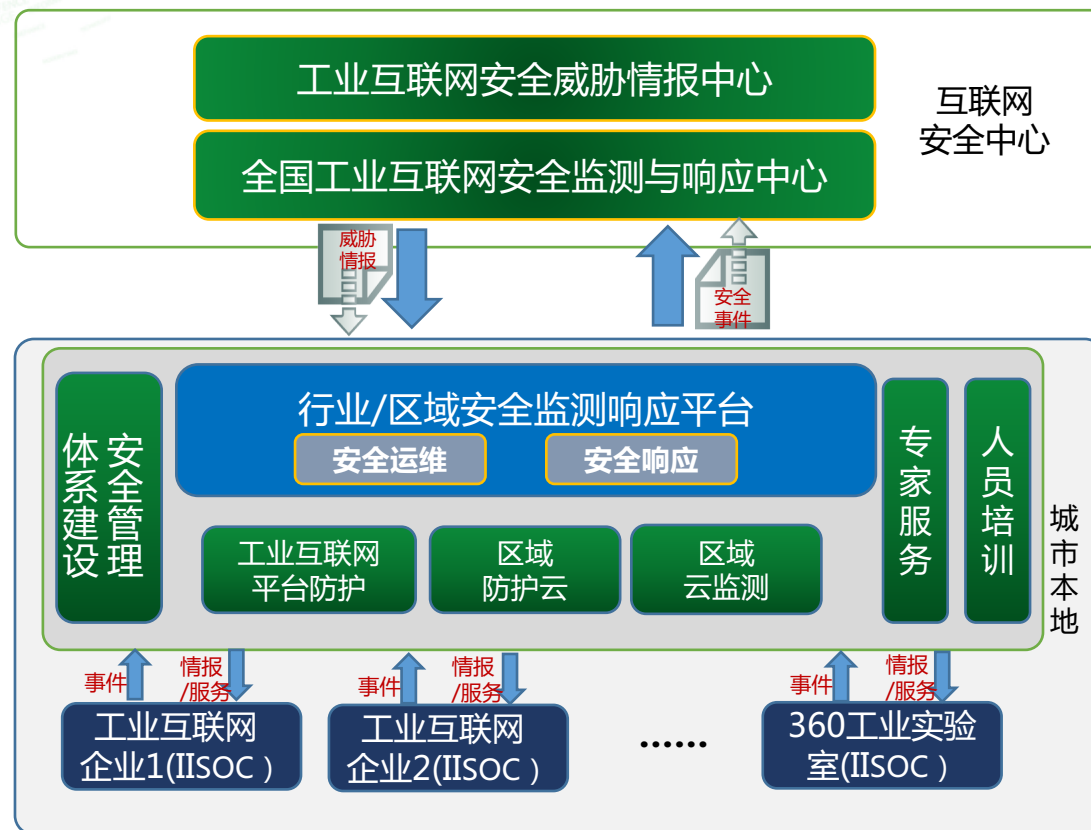
高位能力(High)

- 威胁情报
- 云端安全大数据

防御技术路线：多级安全服务体系

目标

协同防御：构建工业互联网企业安全共同体



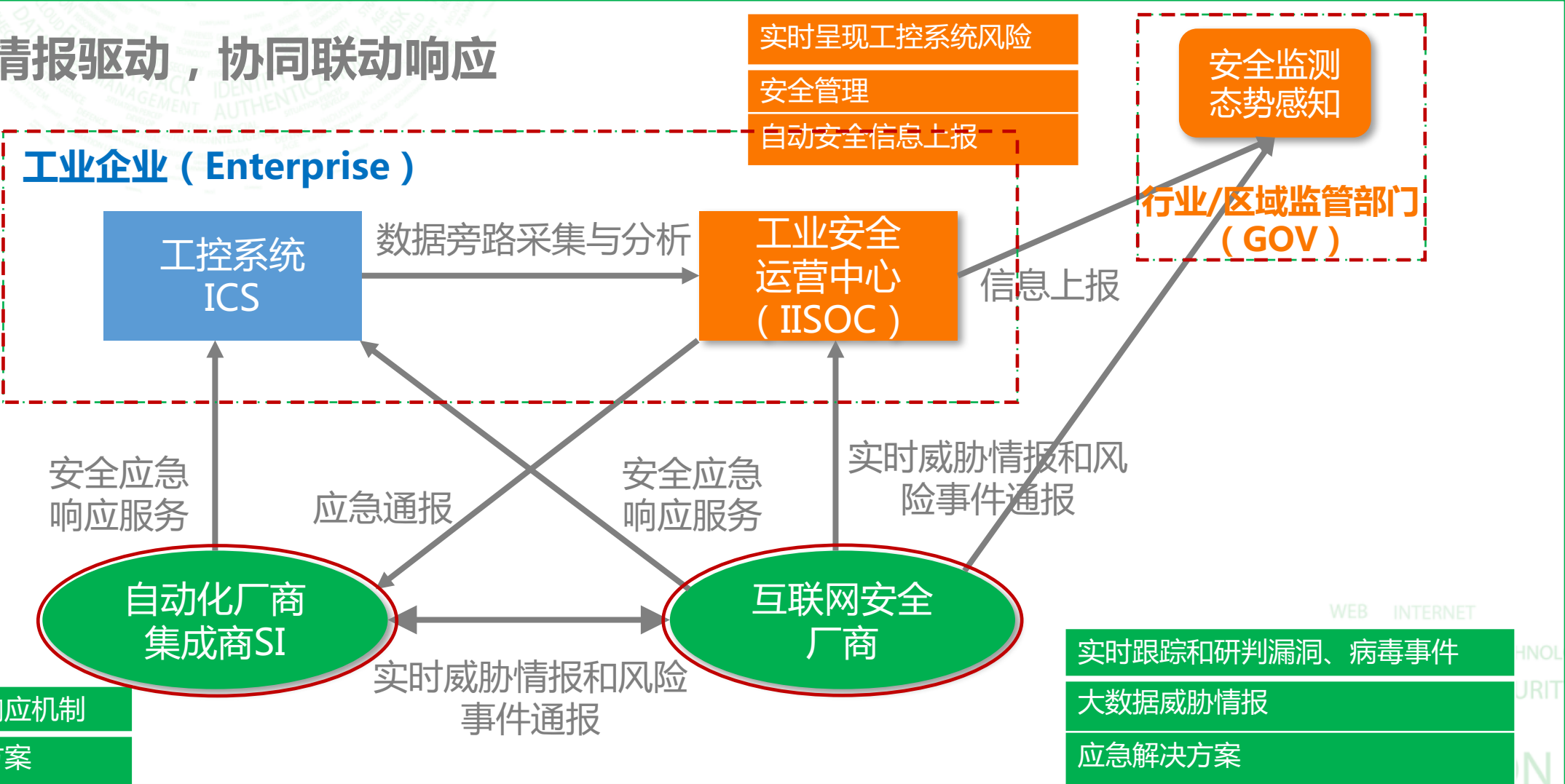
安全
服务

ZERO TRUST SECURITY

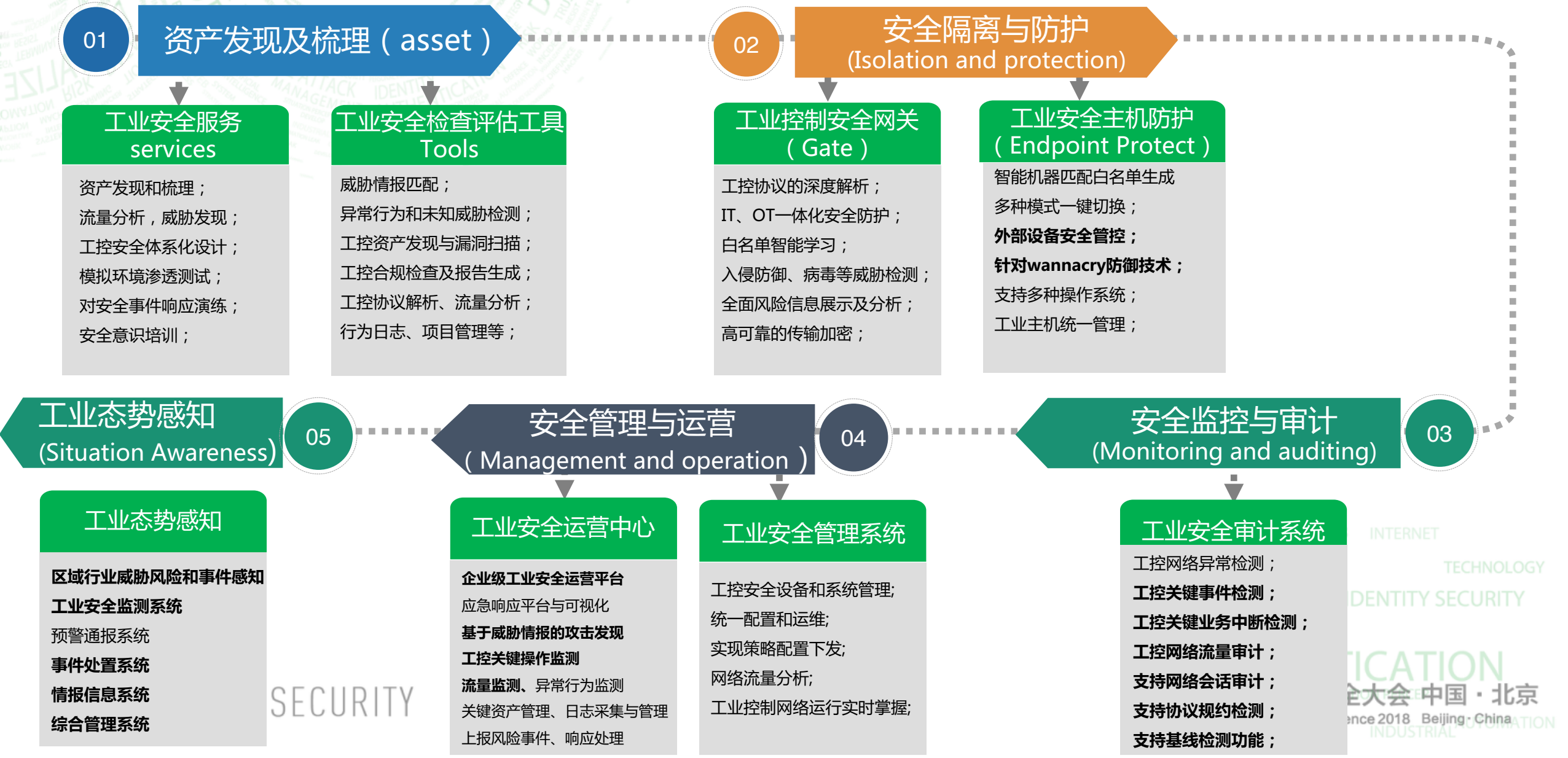
协同联动：建立工控安全应急响应协同机制



威胁情报驱动，协同联动响应



工业互联网安全工作思路





ISC 互联网安全大会



360 互联网安全中心

工业互联网安全战略推进建议

PROPOSALS FOR PROMOTING INDUSTRIAL INTERNET SECURITY STRATEGY

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

IT/OT一体化安全的战略推进时间表

安全治理是长期且复杂的过程，难以一蹴而就，需要循序渐进



战略路线图时间表



ZERO TRUST SECURITY

战略推进节拍-高优先级（意识、组织、评估、监测）



近期

- **安全意识培训**

大多数安全事件是由于人为错误造成的。人仍然是网络安全环境中**最脆弱**的环节，IT如是，OT亦然。

- **形成一个统一的IT/OT安全治理机构**

统一的IT / OT安全治理机构，由：管理层、IT团队、OT团队成员组成，在实现安全治理时提供最全面、代表企业最根本利益的解决方案。

- **OT资产管理**

对**OT资产**进行充分管理，包括**清点、分类、跟踪记录**等。OT资产一般包括设备、过程、软件、网络资源、人员等。根据OT资产相对应的风险等级，制定安全应对方案。

- **对目标系统的安全评估**

确定系统中存在的**安全风险**。包括：远程访问、VLAN不当使用、BYOD安全控制、第三方服务水平平等

- **利用监测工具提高OT资产可见性**

- 可以有效利用**资产发现工具**，对OT资产进行发现和管理，提高**可见性和可控性**。

战略推进节拍-中优先级（运营、流程、系统）



中期

- **继续将统一的IT/OT安全治理工作正式化**

- OT安全功能范围的**准确划分**、选择合适的**安全模型**、什么技能至关重要、哪些技术需要更改

- **建立共同的IT/OT安全运营模式，建立联合角色、责任、流程和系统**

- 确定了**OT安全运营内容**。资产和系统之间的**互联和关系**的复杂性和**指数级增长**，IT、OT和安全功能的**纵向和横向集成和融合**，网络威胁不断增长，需要更灵活和响应的运营模式。

- **修订现有安全策略框架**

- 针对IT和OT的角色和责任定制安全策略或**更新现有安全策略**、保证宣贯和落地

- **OT网络及安全防护建设**

网络分割、身份和访问控制管理、远程访问控制、无线网络安全控制等。OT网络中无线网络安全控制要一同部署，保障OT安全

- **使用工业防火墙、主机防护实施IT/OT网络安全控制**

- OT系统中存在许多架构限制，选择合适的工业防火墙可有效解决工业网络分段和安全控制问题。选择合适的主机防护和工业主机防护，保护端点安全问题

- **持续实施安全监测**

开始并持续实施安全监测，例如实施配置管理、变更管理、定期审计等。

战略推进节拍-低优先级（持续运营、评估、改进）



ISC 互联网安全大会



CSO 互联网安全中心

远期

- **定期进行测试**

定期进行外部**渗透测试**、漏洞扫描等安全测试工作。

- **应用新的OT安全工具和技术**

- 发现、引入先进的IT、OT安全工具和技术，进行的概念验证、实现、测试、部署、维护

- **衡量和控制**OT安全流程及其有效性

- **持续评估**综合IT/OT安全级别

- **识别**可能影响OT功能的基础设施和系统的潜在变化

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



谢谢！